Security — app lock and on-device data

Epic: EPIC-018 (#214), task #222 · **Requirements:** A-05, A-20 · **Related:** rules-indexes.md for server-side protection

Problem

Kavindu's whole financial picture sits on his phone: income, balances, invoices and the goal. A shared or lost phone should not show it to anyone who picks it up. The protection must not add login friction, because "every tool was too unpleasant to open daily" (**A-20**). The cloud copy is already owner-only by the Firestore rules (**A-05**); this section covers the copy on the device.

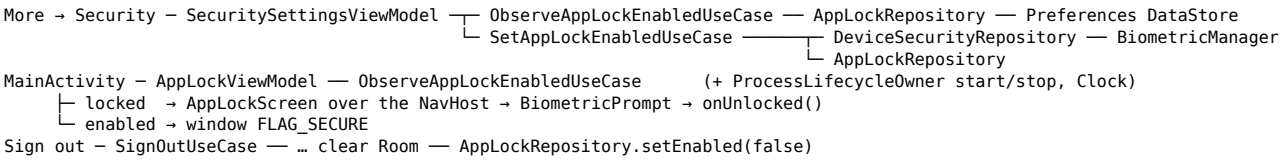
Design decision

- **Optional and off by default.** More → Security → *App lock*. The setting is a device-only boolean in Preferences DataStore. It is not Room, because it isn't transactional data and nothing queries it. It is not Firestore, because a lock on one phone must not follow the account to another.
- **The phone's own authentication.** Unlocking uses `BiometricPrompt` with `BIOMETRIC_WEAK` or `DEVICE_CREDENTIAL`: fingerprint or face, with the phone's PIN, pattern or password as the fallback. This works on API 26+ and with no biometric enrolled. Turning the lock on first checks `BiometricManager.canAuthenticate` with the same authenticators. Without a screen lock, the toggle stays off and says "Set a screen lock in phone settings first", because otherwise the user could lock themselves out.
- **When it locks.** On a cold start, and when the whole app returns from the background after **more than 60 s**. "Whole app" is measured with `ProcessLifecycleOwner`, so the system prompt itself or a rotation doesn't count. Turning the lock on mid-session doesn't lock immediately.
- **What locked means.** A full-screen, opaque, touch-swallowing cover is drawn over the app. The app stays composed underneath so the navigation back stack survives, but it is removed from the accessibility tree (`clearAndSetSemantics`), so TalkBack can't read it either. The prompt opens automatically. Cancelling leaves the lock screen with an *Unlock* button.
- **Screenshots and recents.** While the lock is on, the window has `FLAG_SECURE`. Screenshots and screen recording are blocked, and the recent-apps preview is blank.
- **Sign-out** turns the lock off and clears the setting (`SignOutUseCase`, after local data is cleared). The next account on the phone starts without it.

What the app does not do

- **No biometric data is stored or transmitted.** FundTrail never sees a fingerprint, face or PIN. The prompt is the system's own; the app only receives "succeeded" or "cancelled". Nothing about the lock leaves the device.
- **Room is not encrypted by the app.** The local database is protected by the Android app sandbox (other apps can't read it) and by the phone's own full-disk or file-based encryption, which is on by default since Android 10 and on most devices before that. A rooted or forensically imaged phone could read it.
- **Future work: SQLCipher** (`net.zetetic:sqlcipher-android`) would encrypt Room with a key held in the Android Keystore. It is out of scope for M3: it adds a native dependency and a migration of the existing database, and the threat it covers (a rooted or imaged phone) is beyond the scenario's "shared or lost phone".

Data flow



Edge cases handled

Case	Behaviour
No screen lock on the phone	The toggle stays off with an explanation (no lock-out).
No fingerprint enrolled	The prompt falls back to the PIN, pattern or password (DEVICE_CREDENTIAL).
Prompt cancelled	Stays locked. The *Unlock* button reopens it; no crash.
Back within 60 s (e.g. checking a message)	Not locked again.
Rotation or another configuration change	The ViewModel survives and the state is kept; no extra lock.
Lock turned on during a session	Applies from the next cold start or long background, not immediately.
TalkBack while locked	Only the lock screen is announced.
Sign-out	The lock is off and the setting is cleared for the next user.

Screenshots

[Image: More → Security with the App lock toggle]	**[Image: Lock screen with Unlock]**
More → Security → App lock.	The lock screen after the prompt was cancelled.

Tests

- AppLockViewModelTest: cold start locked or open, unlock, back under 60 s, back after 2 min, enabled mid-session, disabled while locked.
- SetAppLockEnabledUseCaseTest: enable with and without a screen lock; disabling always allowed.
- SecuritySettingsViewModelTest: the "set a screen lock" message and clearing it.
- SignOutUseCaseTest: the lock is cleared on sign-out and kept when sign-out fails.
- On a device: background for 2 min then return, PIN fallback with no fingerprint enrolled, screenshot and recents blocked. This is the manual check listed in the PR.